

PLAN DE RESPUESTA A INCIDENTES BASADO EN LA GUÍA NIST SP 800-61 -4GEEKS ACADEMY-

SARA MARTÍ
18/05/2026

CONTENIDO

INTRODUCCIÓN	1
ALCANCE	2
MARCO DE REFERENCIA	2
PLAN DE RESPUESTA A INCIDENTES BASADO EN NIST SP 800-61	3
PREPARACIÓN	3
RESPONSABLES DEFINIDOS	3
MEDIOS Y HERRAMIENTAS.....	3
MEDIDAS PREVENTIVAS.....	4
DETECCIÓN Y ANÁLISIS	5
CONTENCIÓN	6
ERRADICACIÓN	7
RECUPERACIÓN	8
LECCIONES APRENDIDAS.....	9
RESPUESTA ANTE UN ATAQUE SIMILAR	10
MECANISMOS DE PROTECCIÓN DE DATOS	10
COPIAS DE SEGURIDAD PERIÓDICAS	10
CIFRADO DE DATOS SENSIBLES	11
CONTROLES DE ACCESO ESTRICTOS.....	11
SGSI BÁSICO ISO/IEC 27001	12
ALCANCE DEL SGSI	12
ANÁLISIS DE RIESGOS	12
POLÍTICAS DE SEGURIDAD.....	13
PLANES DE ACCIÓN	14
MEJORA CONTÍNUA	14
CONCLUSIÓN	14

INTRODUCCIÓN

En esta tercera fase del proyecto, el objetivo es desarrollar un **Plan de Respuesta a Incidentes** basado en la guía **NIST SP 800-61**, junto con una propuesta básica de **SGSI** (Sistema de Gestión de Seguridad de la Información) conforme a **ISO/IEC 27001**.

Después de haber analizado el incidente en la fase forense y de haber corregido vulnerabilidades en el servidor Debian, en esta parte se centra en dejar definido cómo debería actuar la organización ante futuros incidentes de seguridad.

El caso analizado a partir de un servidor Debian comprometido, donde se detectaron accesos no autorizados, servicios expuestos como SSH, FTP y Apache/WordPress, credenciales débiles y comprometidas, además permisos inseguros en archivos y directorios críticos, como el entorno web y el archivo **wp-config.php**. Estos cambios no solo representan una mala configuración, sino que también pueden interpretarse como indicios de una posible preparación previa del entorno, al facilitar acciones posteriores como la lectura de credenciales o carga de archivos maliciosos.

Por todo esto, no es suficiente corregir las malas configuraciones y deshacer los cambios del atacante. También es necesario contar con un procedimiento claro para detectar un incidente, analizarlo, contenerlo, eliminar la causa, recuperar el sistema y aplicar mejoras para que no vuelva a repetirse.

Además, se plantea un SGSI básico alineado con ISO 27001, incluyendo análisis de riesgos, políticas de seguridad, control de accesos, copias de seguridad, protección de datos sensibles y mejora continua. De esta forma la organización podrá responder de forma coordinada a un ataque y mejorar su forma de gestionar la seguridad.

ALCANCE

El alcance se centra en el servidor Debian comprometido y en los servicios relacionados con el incidente.

Se incluyen dentro del alcance:

- Servidor Debian.
- Servicio SSH.
- Servicio FTP.
- Servidor web Apache.
- WordPress y sus archivos de configuración.
- Base de datos MariaDB/MySQL.
- Archivos críticos como wp-config.php, /etc/ssh/sshd_config y /etc/vsftpd.conf .
- Usuarios, credenciales, permisos, logs y copias de seguridad.
- Actualizaciones y parches de seguridad.

También se tienen en cuenta las medidas necesarias para proteger la información, controlar los accesos, mejorar la monitorización y reducir la posibilidad de que un incidente similar vuelva a producirse.

Centrándose el plan en definir cómo debería actuar la organización para preparar, detectar, contener, erradicar y recuperar sus sistemas ante futuros incidentes de seguridad.

MARCO DE REFERENCIA

Se toman como referencia dos marcos:

NIST SP 800-61, como guía para organizar la respuesta ante incidentes de seguridad, estructurando las acciones que debe seguir la organización para detectar y analizar un incidente, contenerlo, erradicar la causa, recuperar los sistemas afectados y documentar las lecciones aprendidas.

ISO/IEC 27001, como referencia para plantear un Sistema de Gestión de Seguridad de la Información, su finalidad es poder gestionar los riesgos de forma continua mediante políticas, controles y planes de acción.

De esta forma se combina en la parte operativa de respuesta ante incidentes, con la parte organizativa, orientada a proteger la información crítica y mejorar la seguridad de forma continua.

PLAN DE RESPUESTA A INCIDENTES BASADO EN NIST SP 800-61

Este plan propone organizar la actuación ante un incidente en varias fases: preparación, detección y análisis, contención, erradicación, recuperación y lecciones aprendidas.

En este proyecto, se aplica al caso del servidor Debian comprometido, con el objetivo de que la organización esté preparada, teniendo una forma clara de actuar, si volviera a producirse un ataque similar.

PREPARACIÓN

Aquí se definen los responsables, los medios y las medidas necesarias antes de que ocurra un incidente. Su objetivo es evitar una respuesta improvisada y descoordinada reduciendo así el impacto de un ataque.

RESPONSABLES DEFINIDOS

ROL	FUNCIÓN DENTRO DEL PLAN DE RESPUESTA
Responsable de seguridad	Coordina la respuesta al incidente, toma decisiones principales y supervisa que se sigan los pasos definidos en el plan.
Analista de seguridad/forense	Revisa logs, evidencias y actividad sospechosa para identificar el origen, alcance e impacto del incidente.
Administrador de sistemas	Aplica medidas técnicas, modifica configuraciones, restaura servicios y valida que el sistema quede seguro.
Responsable de comunicación	Informa internamente del estado del incidente y coordina la comunicación exterior si fuera necesario.
Usuarios	Cumplen políticas de seguridad y avisan ante comportamientos sospechosos, accesos extraños o posibles errores de seguridad.

MEDIOS Y HERRAMIENTAS

HERRAMIENTA O RECURSO	UTILIDAD
Wazuh (SIEM)	Centralizar y correlacionar eventos de seguridad. Puede recoger los del sistema, SSH, FTP, Apache y alertar sobre accesos sospechosos, errores repetidos o actividad anómala.
Wazuh FIM (File Integrity Monitoring)	Detectar modificaciones no autorizadas en archivos y directorios críticos, como wp-config.php, /etc/passwd, /etc/ssh/sshd_config o /var/www/html.
Journalctl	Consultar manualmente logs del sistema y servicios en Debian, especialmente eventos relacionados con SSH, sesiones de usuario y actividad sospechosa.
Logs de Apache	Revisar manualmente accesos web, peticiones sospechosas y actividad relacionada con WordPress cuando sea necesario.
Fail2Ban	Herramienta de prevención a nivel de host. Analiza logs de distintos servicios, como SSH, FTP o Apache, y bloquea IPs con patrones sospechosos.
Firewall	Limitar conexiones innecesarias, bloquear IPs sospechosas y reducir la exposición del servidor.

ClamAV / chkrootkit	Analizar el sistema en busca de posibles rootkits, binarios alterados, indicios de persistencia o malware.
Copias de seguridad	Permitir la recuperación del sistema, la base de datos y los archivos web si se produce pérdida o alteración de la información.
Documentación de evidencias	Registrar acciones realizadas, logs conservados, cambios aplicados y decisiones tomadas durante la respuesta.

MEDIDAS PREVENTIVAS

MEDIDA	APLICACIÓN
Política de contraseñas robustas	Utilizar contraseñas largas, únicas y no reutilizadas para usuarios del sistema, WordPress y base de datos.
Control de acceso y autenticación MFA	Limitar el acceso a los servicios críticos solo a usuarios autorizados e implementar autenticación multifactor en accesos administrativos, especialmente en WordPress, paneles de gestión y accesos remotos.
Principio de mínimo privilegio	Asignar a cada usuario, servicio o archivo solo los permisos necesarios para cumplir su función, aplicándolo especialmente al directorio web /var/www/html y a archivos críticos como wp-config.php
Deshabilitar SSH como root.	Evitar que el usuario root pueda iniciar sesión directamente por SSH.
Uso de claves SSH	Uso de claves en lugar de contraseñas para conexiones remotas.
Fail2Ban en servicios expuestos.	Aplicar protección frente a intentos repetidos de acceso, evitando así fuerza bruta.
Restricción o sustitución de FTP	No mantener expuesto el servicio FTP de forma permanente. Deshabilitándolo o sustituyéndolo por SFTP
Actualizaciones y parches de seguridad	Mantener actualizado el servidor Debian, Apache, WordPress, temas, plugins y servicios instalados.
Copias de seguridad periódicas y regla 3-2-1	Programar backups periódicos del directorio web, la base de datos y archivos críticos de configuración. Aplica la regla 3-2-1: tres copias de los datos, en dos soportes diferentes y unacopia externa aislada del servidor principal.
Pruebas de restauración	Comprobar periódicamente que las copias de seguridad pueden restaurarse correctamente y que no están corruptas o incompletas.
Simulacro y revisiones del plan	Revisar el procedimiento para comprobar que el equipo sabe cómo actuar ante un incidente.
Capacitación del personal en ciberseguridad.	Formar al personal en buenas prácticas de seguridad, detección de actividad sospechosa y notificación temprana de incidentes.

DETECCIÓN Y ANÁLISIS

Esta fase consiste en identificar cuanto antes si se está produciendo un incidente, confirmar si se trata de un acceso no autorizado o actividad sospechosa y valorar su alcance e impacto. En este caso, se revisan principalmente los accesos al servidor Debian, los servicios expuestos y los cambios en archivos críticos.

Las principales fuentes de detección serían:

FUENTE DE DETECCIÓN	QUÉ SE REvisa
Journalctl y logs del sistema	Accesos SSH, sesiones de usuario, intentos fallidos y actividad anómala.
Wazuh / SIEM	Alertas relacionadas con accesos sospechosos, cambios en archivos críticos o eventos repetidos.
Logs de Apache	Peticiones sospechosas, accesos a WordPress, errores repetidos o rutas anómalas.
Logs de FTP / vsftpd	Intentos de autenticación, accesos no autorizados, subida o descarga de archivos
Wazuh FIM	Cambios no autorizados en wp-config.php, /etc/ssh/sshd_config, /etc/vsftpd.conf o /var/www/html

En este escenario, la detección no debe centrarse únicamente en accesos no autorizados, errores repetidos o intentos fallidos de autenticación. También debe contemplar cambios internos anómalos que puedan indicar una fase previa de preparación del compromiso. Por ejemplo, modificaciones de permisos en /var/www/html, cambios sobre wp-config.php, alteraciones en configuraciones como /etc/ssh/sshd_config, /etc/vsftpd.conf o /etc/apache2/apache2.conf, creación de usuarios, cambio de privilegios o uso indebido de cuentas administrativas. Este tipo de actividad puede pasar desapercibida si solo se revisan intentos de acceso externos, por lo que resulta importante monitorizar también la integridad de archivos y configuraciones críticas.

CATEGORÍA	EJEMPLO	GRAVEDAD
Instalación o activación de servicios no autorizados	Paquetes instalados sin justificación, servicios nuevos habilitados o tareas programadas sospechosas.	Alta
Acceso no autorizado	Inicio de sesión SSH no reconocido o acceso como root.	Crítica
Compromiso de credenciales	Uso de contraseñas débiles o credenciales expuestas en servicios como WordPress o MariaDB.	Alta
Modificación de archivos críticos	Cambios en wp-config.php, /var/www/html o archivos de configuración de Apache	Alta
Exposición de servicios inseguros	FTP accesible o mal configurado	Alta
Actividad web sospechosa	Peticiones anómalas en Apache/WordPress o posible subida de archivos no autorizados	Alta
Posible preparación previa del entorno.	Cambios inseguros de permisos, modificación de configuraciones críticas como SSH, FTP o Apache o uso de privilegios para dejar el sistema más vulnerable antes de un compromiso.	Alta / Crítica

Durante esta fase también se debe conservar la evidencia disponible antes de modificar el sistema. En este caso serían importantes:

- Logs de autenticación y eventos del sistema.
- Logs de Apache, FTP y SSH
- Imagen forense del servidor comprometido
- Capturas de configuraciones inseguras o permisos incorrectos.
- Hashes de la imagen o de archivos relevantes.

Esta fase permite confirmar si el incidente sigue activo, qué servicios se han visto afectados y qué acciones deben priorizarse en la fase de contención.

CONTENCIÓN

El objetivo de esta fase es frenar el incidente lo antes posible para evitar que el atacante mantenga el acceso, modifique más archivos o afecte a otros servicios. No se trata de dejar el sistema completamente limpio, sino de **limitar el daño y estabilizar la situación**.

En el caso del servidor Debian analizado, la contención se centraría en aislar el sistema comprometido, controlar los accesos y proteger las evidencias antes de corregir el sistema.

ACCIÓN DE CONTENCIÓN	APLICACIÓN	OBJETIVO
Aislar temporalmente el servidor.	Limitar o cortar la conectividad del servidor	Evitar que el atacante mantenga conexión o que el compromiso se extienda.
Detener servicios afectados	Detener temporalmente servicios como FTP, Apache o SSH si están siendo utilizados durante el compromiso.	Reducir la superficie de ataque mientras se analiza la situación y revisar su configuración.
Bloquear IPs sospechosas	Aplicar reglas de firewall para bloquear la IP relacionada con accesos no autorizados o intentos repetidos	Cortar el acceso desde orígenes identificados como maliciosos.
Cambiar credenciales comprometidas	Cambiar contraseñas de usuarios del sistema, WordPress y MariaDB/MySQL si existe sospecha de compromiso.	Cortar el uso de credenciales débiles o robadas.
Revisar sesiones y procesos activos.	Comprobar usuarios conectados, procesos extraños y conexiones activas.	Detectar si el atacante sigue dentro del sistema.
Preservar evidencias	Guardar logs, capturas, copia forense o registros relevantes antes de modificar el sistema.	Mantener la trazabilidad del incidente para el análisis posterior.

Durante esta fase es importante actuar rápido, pero sin borrar evidencias necesarias para entender qué ha ocurrido. Por ejemplo, antes de eliminar archivos sospechosos o cambiar configuraciones críticas, se deben conservar los logs, capturas y datos relevantes del sistema.

En este caso, la contención priorizaría la restricción de servicios como SSH, FTP y Apache, conservando así las evidencias relacionadas con los cambios de permisos y accesos detectados durante el análisis forense.

ERRADICACIÓN

Esta fase consiste en eliminar la causa del incidente y cualquier elemento que pueda permitir al atacante mantener el acceso al sistema, revertiendo los cambios procedentes del incidente, corrigiendo las configuraciones inseguras, eliminando posibles accesos no autorizados y hardening del servidor.

En el caso del servidor Debian, la erradicación se centraría en revisar usuarios, servicios, archivos modificados, credenciales y posibles mecanismos de persistencia.

ACCIÓN DE ERRADICACIÓN	APLICACIÓN	OBJETIVO
Revisar usuarios de sistema	Comprobar usuarios locales, grupos y privilegios asignados.	Detectar cuentas no autorizadas o usuarios con permisos excesivos.
Revisar usuarios de WordPress	Comprobar cuentas administradoras y eliminar usuarios sospechosos.	Evitar accesos no autorizados al panel de WordPress.
Eliminar archivos sospechosos	Revisar /var/www/html, uploads de Wordpress, /tmp y otros directorios donde puedan haberse subido scripts o webshells.	Eliminar posibles puertas traseras o archivos maliciosos.
Corregir permisos inseguros	Revisar y corregir permisos en /var/www/html, evitando permisos 777	Impedir modificaciones o lecturas no autorizadas.
Proteger wp-config.php	Aplicar permisos restrictivos y revisar que las credenciales sean robustas.	Proteger información sensible de conexión con MariaDB/MySQL.
Endurecer SSH	Deshabilitar el acceso directo como root, limitar usuarios permitidos e implementar claves SSH.	Reducir el riesgo de nuevos accesos no autorizados.
Revisar FTP / vsftpd	Deshabilitar FTP y si fuera necesario sustituirlo por SFTP.	Eliminar un servicio inseguro expuesto.
Revisar paquetes y servicios instalados.	Comprobar logs de apt/dpkg, servicios activos con systemctl y tareas programadas.	Detectar herramientas instaladas por el atacante o mecanismos de persistencia.
Actualizaciones y parche sistema y aplicaciones	Actualizar Debian, Apache, WordPress, temas, plugins y servicios instalados.	Corregir vulnerabilidades conocidas.
Escanear malware y rootkits	Ejecutar herramientas como ClamAV o chkrootkit.	Detectar indicios de compromiso persistente.

Aunque es haya bloqueado el acceso inicial, el atacante podría haber creado usuarios, dejado archivos maliciosos, modificado permisos o instalados servicios para recuperar el acceso más adelante.

La erradicación priorizaría la eliminación de posibles archivos sospechosos en el entorno web, la corrección de permisos inseguros, el cambio y protección de credenciales, configuración segura para SSH y la revisión del servicio FTP para evitar que vuelva a ser utilizado como vía de acceso o transferencia no autorizada.

RECUPERACIÓN

Esta fase tiene como objetivo restaurar el funcionamiento normal del sistema, pero siempre de forma controlada y segura. No se trata solo de volver a levantar servicios, sino de comprobar antes que el atacante ya no mantiene acceso y que las configuraciones corregidas funcionan correctamente.

En el caso del servicio Debian analizado, la recuperación se centraría en restaurar los servicios afectados, validar WordPress y MariaDB/MySQL, revisar los logs posteriores y comprobar que las medidas aplicadas no han roto el funcionamiento del sistema.

ACCION DE RECUPERACIÓN	APLICACIÓN	OBJETIVO
Verificar que el incidente está contenido y erradicado.	Comprobar que no hay sesiones o procesos sospechosos ni conexiones activas no autorizadas.	Asegurar que el atacante no sigue dentro del sistema antes de restaurar los servicios.
Restaurar servicios de forma progresiva.	Activar de nuevo Apache, SSH o servicios necesarios, revisando su comportamiento después de cada cambio.	Recuperar la operativa sin reabrir el riesgo de golpe.
Validar Apache y WordPress.	Comprobar que la web carga correctamente, que no hay archivos sospechosos y que el panel de administración queda protegido.	Confirmar que la aplicación web funciona de forma segura.
Validar MariaDB/MySQL.	Comprobar la conexión de WordPress con la base de datos y revisar usuarios y privilegios.	Asegurar que la base de datos funciona y que no mantiene accesos indebidos.
Restaurar desde copia limpia si es necesario.	Utilizar backups verificados del directorio web, base de datos o sistema si se detecta alteración grave.	Recuperar información íntegra y evitar mantener archivos comprometidos.
Comprobar permisos y configuraciones.	Revisar permisos en /var/www/html, wp-config.php, SSH, FTP y Apache.	Confirmar que las correcciones siguen aplicadas y que no rompen el servicio.
Revisar logs posteriores.	Monitorizar journalctl, logs de Apache, Wazuh/SIEM y alertas durante los días posteriores.	Detectar nuevos intentos de acceso o señales de reinfección.
Documentar las correcciones.	Registrar servicios restaurados, cambios aplicados, fecha, responsable y comprobaciones realizadas.	Mantener trazabilidad del proceso y facilitar auditorías posteriores.

En esta fase es importante recuperar el sistema de forma ordenada, Si se restauran los servicios sin comprobar antes que el incidente ha sido erradicado, existe el riesgo de que el atacante vuelva a aprovechar la misma vía de acceso o que se mantenga algún mecanismo de persistencia.

En este caso, la recuperación prioriza validar que el servidor Debian vuelve a funcionar correctamente, que WordPress puede conectarse con MaríaDB/MySQL, que los permisos inseguros han sido expuestos, los servicios expuestos quedan limitados y monitorizados y que las credenciales fueron cambiadas por otras robustas y únicas.

LECCIONES APRENDIDAS

Una vez contenido y recuperado el incidente, se pasa a documentar las lecciones aprendidas, revisando qué ha ocurrido, qué ha funcionado bien, qué ha fallado y qué medidas deben mejorarse para que vuelva a producirse un incidente similar.

En el caso del servidor Debian analizado, esta fase permitiría valorar si la detección fue suficientemente rápida, si las medidas de contención fueron adecuadas y si las correcciones aplicadas realmente reducen el riesgo de repetición de un incidente similar.

ACCIÓN	APLICACIÓN	OBJETIVO
Reunión post-incidente	Reunir a los responsables implicados para revisar cómo se gestionó el incidente.	Identificar aciertos, fallos y puntos de mejora.
Análisis de causa raíz.	Revisar cómo se produjo el acceso no autorizado y qué debilidades lo facilitaron.	Evitar que el mismo vector de ataque vuelva a repetirse.
Revisión de tiempos de respuesta.	Valorar cuánto se tardó en detectar, contener, erradicar y recuperar el sistema.	Mejorar la rapidez de actuación ante futuros incidentes.
Revisión de evidencias.	Análisis de logs, capturas, hallazgos de Autopsy y cambios detectados en el sistema.	Confirmar el alcance real del incidente y reforzar la investigación.
Evaluación de controles aplicados.	Comprobar si Fail2Ban, firewall, permisos seguros, cambios de contraseñas, corrección de configuraciones inseguras y hardening fueron suficientes.	Validar la eficacia de las medidas implantadas.
Actualización del plan	Corregir procedimientos incompletos o poco claros.	Mantener el plan útil y adaptado al entorno real.
Formación y concienciación.	Reforzar buenas prácticas sobre contraseñas, accesos, WordPress y notificación temprana.	Reducir errores humanos y mejorar la detección inicial.
Simulacros periódicos.	Practicar escenarios similares de acceso no autorizado o compromiso web.	Comprobar que el equipo sabe actuar y que el plan funciona.

Como resultado de esta fase, la organización debería actualizar sus políticas de seguridad, mejorar la monitorización, revisar periódicamente permisos y usuarios, comprobar las copias de seguridad y documentar cualquier cambio relevante realizado tras el incidente.

Otra lección importante es que el incidente no debe analizarse únicamente como un ataque externo puntual. La existencia de permisos inseguros y cambios sobre elementos críticos del sistema hace necesario contemplar también la posibilidad de una preparación previa del entorno, ya sea por abuso de privilegios, uso indebido de una cuenta legítima o falta de control sobre cambios administrativos. Por ello, además de proteger los servicios expuestos, es necesario mejorar la trazabilidad de las acciones internas, revisar quién puede modificar configuraciones críticas y activar controles de integridad sobre archivos sensibles.

En este caso, las principales lecciones aprendidas se relacionan con la necesidad de limitar los servicios expuestos, impedir accesos administrativos inseguros, aplicar contraseñas robustas y únicas, proteger archivos críticos, controlar los permisos del entorno web y mantener una monitorización continua de logs y cambios del sistema.

RESPUESTA ANTE UN ATAQUE SIMILAR

Si la organización sufriera un ataque similar al analizado en este proyecto, se activaría el plan de respuesta a incidentes siguiendo las fases definidas anteriormente. El objetivo sería actuar de forma rápida, pero ordenada, para confirmar el incidente, frenar el acceso no autorizado, eliminar la causa y recuperar el sistema de forma segura.

FASE	ACTUACIÓN ANTE ATAQUE SIMILAR	OBJETIVO
Detección inicial.	Revisar alertas de Wazuh/SIEM, journalctl, logs de Apache, registros de SSH y FTP y cambios en archivos críticos.	Confirmar si existe actividad sospechosa o acceso no autorizado.
Análisis del alcance.	Identificar qué usuarios, servicios, archivos o credenciales se han visto afectados.	Conocer el impacto real antes de aplicar cambios.
Contención	Aislar temporalmente el servidor, bloquear IPs sospechosas, restringir servicios expuestos y preservar evidencias.	Evitar que el atacante mantenga acceso o siga modificando el sistema.
Erradicación.	Eliminar archivos sospechosos, corregir permisos, revisar usuarios, cambiar credenciales y endurecer SSH y WordPress. Deshabilitar FTP o sustituir por su versión segura.	Eliminar la causa del incidente y posibles mecanismos de persistencia.
Recuperación.	Restaurar servicios de forma progresiva, validar WordPress y MariaDB/MySQL, revisar logs posteriores y usar backups limpios si es necesario.	Volver a la operativa normal de forma segura.
Prevención de recurrencia.	Mantener Fail2Ban, firewall, mínimo privilegio, copias de seguridad, actualizaciones y parches de seguridad, monitorización y revisión periódica de accesos.	Reducir la probabilidad de que el incidente vuelva a producirse.

En este caso, la respuesta se centraría especialmente en los servicios que tuvieron relación con el incidente: **SSH, FTP, Apache/WordPress y MariaDB/MySQL**. También sería prioritario revisar archivos críticos como wp-config.php, comprobar los permisos del directorio web y verificar que no existan usuarios, procesos o tareas programadas sospechosas. Además, se debería comprobar si antes del acceso no autorizado se produjeron cambios internos anómalos, como modificaciones de permisos, cambios de configuración en SSH, FTP o Apache, o uso indebido de privilegios, indicios que pueden señalar una preparación previa del entorno.

Para prevenir la recurrencia, no bastaría con cambiar una contraseña o bloquear una IP concreta. La organización debería mantener una estrategia más completa basada en control de accesos, contraseñas robustas, MFA en accesos críticos, restricción de servicios innecesarios, monitorización continua, copias de seguridad verificadas y revisiones periódicas del sistema.

MECANISMOS DE PROTECCIÓN DE DATOS

Además de responder al incidente, la organización debe proteger la información crítica para reducir el impacto en caso de compromiso.

COPIAS DE SEGURIDAD PERIÓDICAS

Las copias de seguridad son imprescindibles para poder recuperar el sistema si se produce un robo, modificación o eliminación de la información. En este caso, deben incluir tanto el directorio web como la base de datos y los archivos críticos de configuración.

ELEMENTO	FRECUENCIA	MOTIVO
----------	------------	--------

Base de Datos MariaDB/MySQL	Diaria	Contiene información de WordPress, usuarios, contenido y configuración interna.
Directorio web /var/www/html	Semanal o después de cambios importantes.	Contiene archivos de WordPress, temas, plugins, uploads y posibles modificaciones relevantes.
Archivos de configuración	Después de cada cambio autorizado y mensual.	Incluye archivos como wp-config.php, /etc/ssh/sshd_config y configuración de Apache.
Copia completa del servidor.	Semanal o mensual	Permite recuperar el sistema completo si el compromiso es grave.
Prueba de restauración.	Mensual	Verifica que las copias existen, son íntegras y pueden restaurarse por completo.

Estas copias deberían seguir la regla 3-2-1, manteniendo tres copias de datos, en dos soportes diferentes y una copia externa o aislada del servidor principal. Esto evita que una alteración del servidor afecte a todas las copias disponibles.

CIFRADO DE DATOS SENSIBLES

El cifrado ayuda a proteger la información en caso de acceso no autorizado, especialmente cuando se almacenan copias de seguridad o datos sensibles.

MEDIDA	APLICACIÓN
Cifrado de backups	Proteger las copias de seguridad para evitar que puedan leerse si son robadas o accedidas indebidamente.
Uso de HTTPS/TLS	Asegurar las comunicaciones web entre usuarios y el servidor Apache/WordPress.
Protección de credenciales	Evitar reutilización de contraseñas y proteger archivos que contienen credenciales como wp-config.php
Claves SSH	Usar claves SSH cuando sea posible para reforzar la autenticación remota.

CONTROLES DE ACCESO ESTRICTOS

Los controles de acceso permiten limitar quién puede acceder a cada sistema, servicio, directorio o archivo. El objetivo es evitar accesos no autorizados y reducir el impacto si una cuenta se ve comprometida.

CONTROL	APLICACIÓN
Principio de mínimo privilegio	Cada usuario, servicio, directorio o archivo debe tener solo los permisos necesarios para cumplir su función.
MFA en accesos críticos	Implementar autenticación multifactor en WordPress, paneles administrativos o accesos remotos cuando sea posible.
Deshabilitar SSH como root	Evitar que el usuario root pueda iniciar sesión por SSH.
Revisión periódica de usuarios.	Comprobar cuentas del sistema, WordPress y MariaDB/MySQL para eliminar usuarios innecesarios o sospechosos.
Restricción de FTP	Deshabilitar FTP si no es necesario o sustituirlo por SFTP.
Permisos seguros en archivos críticos.	Proteger /var/www/html, wp-config.php y archivos de configuración evitando permisos inseguros como 777.

Estos controles permiten proteger la confidencialidad, integridad y disponibilidad de la información. En el caso analizado, son especialmente importantes porque el incidente afectó a servicios expuestos, credenciales y permisos sobre archivos críticos del servidor.

SGSI BÁSICO ISO/IEC 27001

El SGSI permite gestionar la seguridad de la información de forma organizada y continua.

Para este proyecto se desarrolla una versión básica adaptada al entorno analizado.

ALCANCE DEL SGSI

Centrado en los sistemas y datos relacionados con el servidor Debian comprometido y los servicios asociados al incidente.

ELEMENTO INCLUIDO	MOTIVO
Servidor Debian	Es el sistema principal donde se encuentran los servicios analizados.
SSH	Permite la administración remota del servidor y debe protegerse para evitar accesos no autorizados.
FTP / vsftpd	Servicio inseguro de transferencia de archivos, no debe exponerse sin control.
Apache / WordPress	Aplicación web accesible desde la red y posible punto de entrada o persistencia.
MariaDB/MySQL	Base de datos utilizada por WordPress, con información y credenciales asociadas.
Wp-config.php	Archivo crítico que contiene datos de conexión a la base de datos.
Logs del sistema y de apache	Permiten detectar actividad sospechosa y reconstruir lo ocurrido.
Usuarios y credenciales.	Deben gestión correcta para evitar accesos no autorizados.
Copias de seguridad.	Permiten recuperar el sistema en caso de pérdida, alteración o compromiso.
Configuraciones críticas	Incluyen archivos como /etc/ssh/sshd_config, /etc/vsftpd.conf y configuración de Apache.

ANÁLISIS DE RIESGOS

El análisis de riesgos permite identificar amenazas, valorar su impacto y definir controles para reducir probabilidades de que se materialicen.

RIESGO	IMPACTO	PROBABILIDAD	NIVEL	CONTROL PROPUESTO
Acceso no autorizado por SSH	Alto	Media	Alto	Deshabilitar acceso root, usar contraseñas robustas o claves SSH, Fail2Ban y firewall.
Credenciales débiles o comprometidas.	Alto	Media	Alto	Política de contraseñas robustas, MFA en accesos críticos y revisión periódica de usuarios.
FTP expuesto o mal configurado.	Medio / Alto	Media	Alto	Deshabilitar FTP si no es necesario o sustituirlo por SFTP.
Permisos inseguros en el entorno web	Alto	Media	Alto	Aplicar mínimo privilegio y revisar permisos en

				/var/www/html y wp-config.php
Modificación de archivos críticos	Alto	Media	Alto	Monitorización con Wazuh FIM y conservación de versiones limpias de configuración.
Pérdida o alteración de datos	Alto	Baja/Media	Alto	Backups periódicos, regla 3-2-1 y pruebas de restauración.
Falta de monitorización	Medio / Alto	Media	Alto	Centralizar logs en Wazuh/SIEM y revisar alertas de seguridad.
WordPress desactualizado o vulnerable	Alto	Media	Alto	Mantener WordPress, temas y plugins actualizados.
Persistencia del atacante	Alto	Baja/Media	Alto	Revisar usuarios, procesos, servicios, tareas programadas y ejecutar análisis con ClamAV y chkrootkit.

POLÍTICAS DE SEGURIDAD

Para que el SGSI funcione, la organización debe definir políticas básicas que indiquen cómo se deben proteger los sistemas y la información.

POLÍTICA	APLICACIÓN
Política de mínimo privilegio.	Limitar permisos de usuarios, servicios, directorios y archivos a lo estrictamente necesario.
Política de control de accesos.	Definir quién puede acceder a SSH, WordPress, MariaDB y otros servicios administrativos.
Política de contraseñas.	Exigir contraseñas robustas, únicas y no reutilizadas.
Política de MFA	Aplicar autenticación multifactor en accesos críticos.
Políticas de copias de seguridad.	Establecer frecuencia, ubicación, protección y pruebas de restauración de backups.
Política de actualizaciones y parches.	Mantener actualizado Debian, Apache, WordPress, temas, plugins y servicios instalados.
Política de monitorización.	Revisar logs, alertas y cambios en archivos críticos mediante Wazuh/SIEM o herramientas similares.
Política de respuesta a incidentes.	Definir cómo detectar, contener, erradicar, recuperar y documentar incidentes.

PLANES DE ACCIÓN

A partir de los riesgos identificados, se definen acciones concretas para proteger la información crítica de la organización.

ACCIÓN	OBJETIVO	PRIORIDAD
Deshabilitar acceso SSH como root.	Reducir el riesgo de compromiso directo al sistema.	Alta
Implantar Fail2Ban en SSH y servicios expuestos.	Bloquear intentos repetidos de autenticación fallida.	Alta
Configurar firewall	Limitar conexiones innecesarias y bloquear orígenes sospechosos	Alta
Revisar permisos de /var/www/html y wp-config.php	Evitar modificaciones o lecturas no autorizadas.	Alta
Cambiar contraseñas comprometidas.	Contraseñas robustas y únicas, evitando así el spraypassword	Alta
Configurar backups 3-2-1	Garantizar la recuperación ante pérdida o alteración de datos.	Alta
Activar monitorización de archivos críticos.	Detectar modificaciones no autorizadas.	Alta
Actualizar WordPress, temas, plugins y sistema	Reducir vulnerabilidades conocidas.	Alta
Revisar usuarios y privilegios	Aplicar mínimo privilegio y eliminar cuentas innecesarias.	Alta
Realizar simulacros de respuesta.	Comprobar que el plan funciona en la práctica.	Media / Alta

MEJORA CONTÍNUA

El SGSI no debe quedarse como un documento estático. Debe revisarse y actualizarse de forma periódica, especialmente después de un incidente o de cambios importantes en el sistema.

Para ello, se deberán realizar las siguientes acciones:

- *Revisar periódicamente el análisis de riesgos.*
- *Comprobar que las políticas de seguridad siguen siendo adecuadas.*
- *Revisar usuarios, permisos y servicios activos.*
- *Comprobar que las copias de seguridad se realizan y se pueden restaurar.*
- *Analizar logs y alertas de seguridad.*
- *Actualizar el plan de respuesta tras cada incidente.*
- *Documentar cambios, evidencias y medidas aplicadas.*
- *Formar al personal implicado en buenas prácticas de seguridad.*

De esta forma, el SGSI permite que la seguridad se gestione de forma continua, no solo como una corrección puntual después de un incidente.

CONCLUSIÓN

En esta fase del proyecto se ha definido un plan de respuesta a incidentes basado en NIST SP 800-61, adaptado al caso del servidor Debian comprometido. El objetivo principal es que la organización no actúe de forma improvisada ante un incidente, sino que tenga claro cómo prepararse, detectar actividad sospechosa, contener el ataque, erradicar la causa, recuperar el sistema y aprender de lo ocurrido.

El incidente analizado demuestra la importancia de controlar los accesos, limitar los servicios expuestos, proteger archivos críticos como wp-config.php y otros archivos de configuración, aplicar contraseñas robustas y no reutilizarlas, revisar permisos y mantener una monitorización adecuada del sistema. También se ha visto que no basta con corregir una vulnerabilidad concreta, sino que es necesario reforzar todo el entorno para reducir la posibilidad de que el ataque se repita.

Además, se ha planteado un SGSI básico conforme a ISO/IEC 27001, centrado en el análisis de riesgos, la definición de políticas de seguridad, los controles de acceso, las copias de seguridad, la protección de datos sensibles y la mejora continua.

En conjunto, este plan permite mejorar la capacidad de respuesta y recuperación de la organización, protegiendo mejor la información crítica y estableciendo una forma más ordenada y segura de gestionar futuros incidentes.